

ThreatGPT: A Hierarchical Multi-Agent Architecture for LLM-Based Cyber Threat Intelligence Analysis

Fadwa Bourrich and Hiba Oujaanine

Université Internationale de Rabat, Morocco
{fadwa.bourrich, hiba.oujaanine}@uir.ac.ma

Abstract. Cyber Threat Intelligence (CTI) analysts face an increasing volume and velocity of unstructured threat data that traditional signature-based and single-model machine-learning pipelines struggle to keep pace with. Large Language Models (LLMs) offer new opportunities for automating extraction, technique mapping, and risk assessment, but existing single-model approaches conflate distinct sub-tasks, rely on static knowledge, and rarely expose their reasoning to analysts. We present ThreatGPT, a hierarchical multi-agent architecture that decomposes LLM-based CTI analysis into three specialised roles: an Extractor Agent, a Mapper Agent that grounds extracted intelligence against the MITRE ATT&CK framework, and a Risk Assessor Agent coordinated through a temporally-weighted retrieval-augmented knowledge layer and a set of adversarial-robustness safeguards. We describe the architecture, its prompting and retrieval design, and its intended evaluation protocol in detail. As a first empirical step, we implement and evaluate a non-LLM TF-IDF retrieval baseline for the Mapper Agent’s core task: mapping free-text threat descriptions to MITRE ATT&CK techniques against a hand-labelled set of 49 CTI sentences and the full current catalogue of 222 top-level Enterprise ATT&CK techniques. This baseline reaches 53.1% top-1 accuracy, 71.4% top-3 accuracy, and a Mean Reciprocal Rank of 0.655, substantially above a random-ranking baseline (MRR 0.027), giving a concrete, reproducible reference point against which the full LLM-based pipeline can later be measured. We discuss why we expect LLM- and RAG-based mapping to improve on this baseline, detail the remaining implementation and evaluation work required to validate the complete three-agent system, and are explicit about what has and has not yet been empirically demonstrated. We argue this staged, transparently-scoped approach is preferable to reporting speculative end-to-end numbers, and we release our baseline code and labelled evaluation set to support reproducible follow-on work.

Keywords: Cyber Threat Intelligence · Large Language Models · MultiAgent Systems · MITRE ATT&CK · Retrieval-Augmented Generation ·

1 Introduction

1.1 Context and Motivation

Security Operations Centres (SOCs) are structurally overwhelmed: enterprise SOCs routinely process well over 100,000 alerts per day, and analysts report spending two to four hours per shift on manual triage, with a substantial fraction of alerts left uninvestigated [1]. The volume of new, publicly disclosed vulnerabilities has grown from a few thousand per year in 2016 to over 46,000 per year in 2025 [2], and open-source threat reporting continues to expand in parallel, far beyond what manual CTI teams can synthesise. At the same time, adversaries are themselves beginning to weaponise AI agents to plan and execute intrusions with reduced human involvement, a shift that recent threat-intelligence reporting shows can produce disproportionately high-risk campaigns without a correspondingly large technique footprint [3].

Traditional CTI automation signature matching, rule-based IOC extraction, and supervised classifiers trained on hand-engineered features struggles to keep pace with this landscape: such systems generalise poorly to novel phrasing, require constant retraining as the threat landscape evolves, and typically address only narrow sub-tasks of the CTI lifecycle [4]. LLMs have recently demonstrated strong performance on exactly the kind of unstructured-text understanding this domain requires, motivating a wave of recent work on LLM-assisted TTP (Tactics, Techniques, and Procedures) extraction, ATT&CK technique mapping, and agentic SOC automation [5,6,7,8].

1.2 Research Gap

Despite this progress, we identify three persistent limitations in the existing literature:

- **Limitation 1 : Monolithic, single-model approaches lack specialisation.** Most LLM-based CTI systems use a single model (often via zero- or few-shot prompting) to perform extraction, technique mapping, and risk interpretation simultaneously [7,9]. This conflates sub-tasks with very different failure modes: entity extraction is fundamentally an information-extraction problem, technique mapping is a large-label-space retrieval problem, and risk assessment requires organisational context that has no natural place in a single prompt.
- **Limitation 2 : Flat or static knowledge grounding.** Retrieval-based mapping systems such as TechniqueRAG embed and index the full, flat set of 200+ ATT&CK techniques uniformly, ignoring the framework's hierarchical tactic/technique/sub-technique taxonomy and the fact that technique

prevalence and adversary tooling shift over time [4]. Static knowledge bases used for extraction and mapping also become stale as new techniques are introduced.

- **Limitation 3 : Limited explainability and robustness.** LLM outputs in this domain are typically returned as final labels without exposed reasoning chains, and current systems are known to be vulnerable to prompt injection and RAG-poisoning attacks: as few as five adversarial documents in a retrieval corpus have been shown to manipulate RAG outputs in up to 90% of queries in controlled studies [16,17]. A CTI system that silently ingests attacker-controlled OSINT text is itself a plausible injection surface.

1.3 Our Contribution

This paper makes the following contributions:

1. A hierarchical multi-agent architecture, ThreatGPT, that decomposes LLMbased CTI analysis into an Extractor Agent, a Mapper Agent, and a Risk Assessor Agent, each with a distinct model role, prompt design, and evaluation protocol (Section 3).
2. A design for temporally-weighted, hierarchy-aware retrieval-augmented knowledge integration intended to address Limitation 2 (Section 3.5).
3. A set of adversarial-defense design principles for LLM-based CTI pipelines, informed by the current prompt-injection and RAG-poisoning literature (Section 3.6).
4. A concrete, reproducible preliminary baseline experiment for the Mapper Agent’s core sub-task CTI-sentence-to-ATT&CK-technique retrieval using the full, current MITRE ATT&CK Enterprise catalogue and a handlabelled evaluation set, which we release together with our code (Section 4).
5. An explicit, honestly-scoped discussion of what remains to be implemented and empirically validated before the full three-agent ThreatGPT pipeline can be claimed to outperform existing single-model or non-agentic baselines (Section 5).

1.4 Paper Organisation

Section 2 reviews CTI fundamentals, LLMs in security, RAG, and multi-agent systems. Section 3 presents the ThreatGPT architecture in full. Section 4 describes our preliminary baseline experiment and its results. Section 5 discusses practical implications, current limitations, and ethical considerations. Section 6 situates ThreatGPT relative to closely related systems. Section 7 concludes and outlines future work.

2 Background and Related Work

2.1 Cyber Threat Intelligence Fundamentals

CTI is commonly described as a lifecycle of collection, processing, analysis, and dissemination, in which raw indicators and unstructured reporting are progressively refined into actionable, decision-relevant knowledge [10]. Early automation efforts relied on signature matching and hand-authored extraction rules; later work applied classical supervised machine learning (e.g., Random Forests, SVMs) over hand-engineered lexical and syntactic features [11]. The MITRE ATT&CK framework has become the de facto standard vocabulary for describing adversary behaviour, organising techniques hierarchically under 14 tactics, and is now the near-universal grounding ontology for automated TTP-extraction research [12].

2.2 Large Language Models in Security

Transformer-based LLMs have been applied across a growing range of security tasks, from vulnerability description understanding to fully agentic penetrationtesting frameworks [13]. Within CTI specifically, recent systems fine-tune or prompt LLMs for TTP extraction [5,6], for ATT&CK mapping [18], and for broader knowledge-graph construction from OSINT under data scarcity [6]. A NeurIPS 2024 benchmark, CTIBench, was introduced specifically to standardise evaluation of LLMs on CTI sub-tasks [9]. Nonetheless, current systematic reviews of LLM-driven cyber defence describe the field as rapidly expanding yet structurally imbalanced, with disproportionate attention to detection and SOC optimisation relative to rigorous, comparable evaluation of CTI reasoning [14].

2.3 Retrieval-Augmented Generation

RAG grounds LLM generation in retrieved external documents, mitigating hallucination and static-knowledge staleness [15]. For ATT&CK mapping specifically, TechniqueRAG embeds the full technique catalogue and retrieves the nearest neighbours to a query passage [4]; recent work has identified that this flat retrieval design discards the taxonomy's hierarchical structure, motivating hierarchy-aware retrieval variants [4]. Separately, a substantial body of recent security research documents that RAG pipelines are themselves attackable: adversarial or poisoned documents inserted into a retrieval corpus can manipulate downstream generation with a small number of crafted documents [16], and the OWASP Top 10 for LLM Applications now lists vector/embedding weaknesses and RAG-specific risks as first-class categories [17].

2.4 Multi-Agent Systems

Decomposing complex LLM tasks across multiple specialised, communicating agents has become a common design pattern, and has been applied specifically to SOC workflows: AgentSOC integrates hypothesis generation, structural validation against enterprise topology, and risk-aware action scoring in a closed loop [1]; a recent industrial case study of a telecommunications-provider SOC similarly reports moving from single-model helpers toward distributed multi-agent CTI pipelines to handle the scale of modern OSINT and vulnerability disclosure volumes [2]. Multi-agent penetration-testing frameworks show comparable specialisation benefits on the offensive side [13]. A recurring theme across this literature is that multi-agent decomposition improves task specialisation and auditability, but introduces new coordination, consistency, and inter-agent trust challenges that single-agent systems do not face [14].

2.5 Threat Intelligence Automation and Positioning

Existing automated CTI tools range from open community tooling to commercial threat-intelligence platforms, and from purely extractive systems to end-to-end agentic pipelines. Relative to this landscape, ThreatGPT's contribution is architectural: an explicit three-stage decomposition (extraction → mapping → risk assessment) with a shared, temporally-weighted, hierarchy-aware knowledge layer and adversarial safeguards designed in from the outset, rather than retrofitted. Section 6 provides a structured qualitative comparison.

2.6 Evaluation Benchmarks and Reliability of LLMs for CTI

Beyond architectural proposals, a parallel line of work has focused on systematically evaluating LLM reliability on CTI sub-tasks, which directly informs the design choices behind ThreatGPT's Mapper and Risk Assessor agents. Building on CTIBench 9, several domain-specific benchmarks have emerged. LLMCloudHunter 20 evaluates LLM-generated detection-rule candidates from cloud-focused OSCTI, reporting 83% precision and 99% recall for extracting attacker API calls and 99%/97% precision/recall for IOCs on a 20-report cloud threat corpus evidence that LLM-based extraction can reach production-relevant accuracy on narrowly scoped sub-tasks, which motivates our decision to isolate extraction, mapping, and risk assessment into separately evaluable agents rather than a single end-to-end model. CyberSOCEval 21, developed with CrowdStrike as part of CyberSecEval 4, evaluates LLMs on Malware Analysis and Threat Intelligence Reasoning via multiple-choice tasks grounded in real sandbox reports and threat-intel documents; notably, its authors find that reasoning-oriented test-time scaling does not yield the same gains observed on coding or mathematical benchmarks, and that models relying on text-only input underperform when the same content

requires interpreting an accompanying report image a finding relevant to any future multimodal extension of the Extractor Agent. Closest in spirit to our adversarial-defense design (Section 3.6) is the empirical study of Meng et al. 22, which argues that LLM unreliability in CTI.

stems less from generic hallucination than from the heterogeneous, volatile, and fragmented nature of the threat landscape itself. Using a human-in-the-loop failure-categorization framework, they identify three domain-specific cognitive failure modes: spurious correlations from superficial metadata, contradictory knowledge across conflicting sources, and constrained generalization to emerging threats and show, via causal intervention, that lightweight, taxonomy-informed defenses (retrieval-based knowledge filtering and inference-time reasoning constraints) measurably reduce failure rates. This taxonomy provides a principled complement to the prompt-injection and RAG-poisoning threat model we adopt in Section 3.6, suggesting that ThreatGPT’s cross-agent consistency checks should be evaluated not only against adversarial inputs but against these naturally occurring epistemic failure modes. On the extraction side, LLM-TIKG 23 is closely related to our Extractor Agent design: it uses GPT’s few-shot capability to annotate and augment training data for fine-tuning a smaller (7B-parameter) open-weight model, which is then used for topic classification and entity/relation extraction from unstructured OSCTI—an approach consistent with our own proposal (Section 3.2) to fine-tune an open-weight model via LoRA/QLoRA for on-premises deployment, rather than relying on a proprietary API for potentially sensitive raw text.

3 Proposed Methodology: ThreatGPT

3.1 System Architecture Overview

Figure 1 depicts the ThreatGPT pipeline as a directed flow: raw inputs (OSINT feeds, CTI reports, social media, internal SOC tickets) enter the Extractor Agent, which emits structured intelligence objects (entities, relations, candidate IOCs, and free-text TTP descriptions). These objects are passed to the Mapper Agent, which grounds each TTP description against the MITRE ATT&CK taxonomy via the shared knowledge layer, producing ranked technique candidates with confidence scores. The Risk Assessor Agent consumes the mapped techniques together with organisational asset and control context to produce a prioritised risk report with recommended mitigations. A cross-cutting consistency and defense layer monitors all three agents’ inputs and outputs for injected instructions, out-of-distribution inputs, and inter-agent disagreement, and can route low-confidence cases to a human analyst.

3.2 Extractor Agent

Role. Convert raw, unstructured text into structured threat-intelligence objects: named entities (malware, threat actors, CVEs, infrastructure indicators), relations between them, and short free-text TTP descriptions suitable for downstream mapping.

Design. We propose a fine-tuned open-weight model (e.g., an 8B-parameter LLaMA-3-class model via parameter-efficient fine-tuning such as LoRA/QLoRA) rather than a proprietary API model, to allow on-premises deployment of raw, potentially sensitive OSINT and internal ticket text. Candidate fine-tuning corpora include the TRAM-annotated report corpus [19] and other publicly released CTI-annotation datasets used in recent extraction work [6,5].

Illustrative prompt template (extraction sub-task):

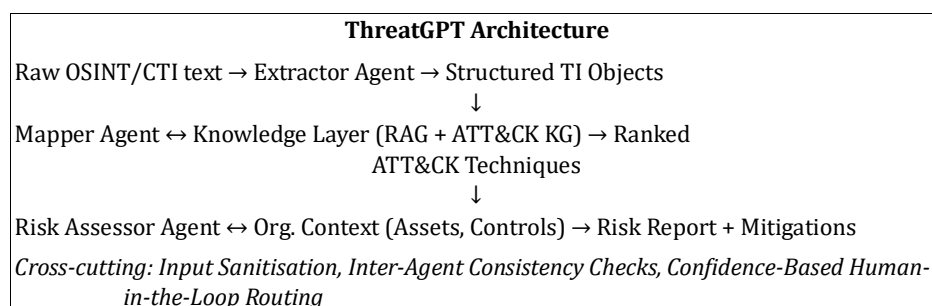


Fig.1. High-level ThreatGPT architecture. Each stage is a distinct agent with its own model, prompt design, and evaluation protocol; a cross-cutting defense layer inspects all agent boundaries.

System: You are a CTI extraction assistant. Given a threat report excerpt, extract: (1) named entities with type labels [malware, threat-actor, CVE, infrastructure, tool]; (2) relations between entities; (3) short (i=25 word) behavioural statements describing observed adversary actions. Output strict JSON. Do not infer facts not present in the text. User: {report excerpt}

Evaluation protocol (proposed). Entity- and relation-level Precision, Recall, and F1 against a held-out annotated test split, following standard NER/RE evaluation practice.

3.3 Mapper Agent

Role. Given a short behavioural statement from the Extractor Agent, retrieve and rank the most plausible MITRE ATT&CK technique(s), with a calibrated confidence score.

Design. We propose an API-based frontier model operating over a hierarchy-aware retrieval index: rather than flat embedding of all techniques, the index first narrows candidates by tactic, then by top-level technique, before ranking sub-techniques reducing the effective label space the generative step must discriminate over.

Confidence scoring. We use temperature-scaled calibration (Equation 3) so that reported confidence approximates true correctness probability, following standard neural calibration practice.

Preliminary baseline. Section 4 reports results for a TF-IDF cosine-similarity retrieval baseline for this sub-task a reference point we expect a properly designed hierarchy-aware LLM+RAG mapper to exceed.

3.4 Risk Assessor Agent

Role. Combine mapped techniques with organisational asset criticality and existing control coverage to produce a prioritised, human-readable risk report with mitigation recommendations aligned to NIST, CIS, or ISO 27001 control catalogues.

Proposed risk scoring. We propose a composite score combining likelihood, impact, and asset criticality:

$$R = L \times I \times C \times \alpha \quad (1)$$

where $L \in [0,1]$ is the estimated likelihood of the mapped technique being used against the organisation (informed by the Mapper Agent's confidence and technique prevalence in the knowledge layer), $I \in [0,1]$ is estimated business impact if the technique succeeds, $C \in [0,1]$ is asset criticality, and α is an organisation-specific calibration constant.

3.5 Dynamic Knowledge Integration

The knowledge layer shared by the Mapper and Risk Assessor agents is designed around three components:

Temporal weighting. Recency-weighted retrieval down-weights older threatintelligence entries relative to newer ones, using exponential decay:

$$w(t) = e^{-\lambda t} \quad (2)$$

where t is the age of a knowledge-base entry and λ controls the decay rate.

Confidence calibration. Following standard temperature scaling:

$$P_{\text{correct}} = \sigma\left(\frac{z}{T}\right) = \frac{1}{1 + e^{-z/T}} \quad (3)$$

where z is the model's raw output logit/score and T is a temperature parameter fit on a held-out calibration set.

Hybrid retrieval. We propose combining dense embedding similarity with sparse lexical retrieval to compensate for the well-documented brittleness of purely dense retrieval on rare technical terminology.

3.6 Adversarial Defense Mechanisms

Given that Extractor Agent inputs are, by design, adversary-influenced text, we treat prompt-injection and RAG-poisoning resistance as a first-class design requirement:

- **Input/instruction separation.** Retrieved and ingested text is architecturally separated from system instructions, rather than concatenated into a single undifferentiated prompt.
- **Cross-agent consistency checks.** Because the Mapper and Risk Assessor agents operate on the Extractor's output rather than raw text, an injected instruction that survives extraction must additionally survive re-interpretation by a differently-prompted downstream agent.

Table 1. Preliminary evaluation setup for the Mapper Agent retrieval baseline.

Component	Value
ATT&CK version	Enterprise v18 (official MITRE STIX release)
Candidate techniques (top-level)	222
Candidate techniques (incl. sub-techniques)	697
Hand-labelled evaluation sentences	49
Annotators	1 (author-labelled)
Label granularity	Top-level technique

- **Confidence-gated human review.** Outputs below a calibrated confidence threshold (Equation 3) are routed to human review rather than auto-published.
- **Retrieval corpus provenance filtering.** Following PoisonedRAG-style findings that a handful of adversarial documents can dominate retrieval [16], we propose weighting retrieval candidates by source provenance/reputation, not similarity alone.

3.7 Illustrative End-to-End Walkthrough

To make the interaction between the three agents concrete, we walk through a single, purely illustrative example. This example is a fabricated composite constructed for expository purposes only; it is not drawn from any specific real world incident or CTI report, and consistent with Section 4.5 it illustrates the intended data flow rather than reporting an empirical result, since only the

Mapper Agent's retrieval sub-task has been implemented and measured.

Input: A short OSINT excerpt is ingested: The intrusion set delivered a macro-enabled spreadsheet via a spoofed vendor-invoice email; once opened, the macro retrieved a second-stage loader from an attacker-controlled domain and established a scheduled task for persistence.

Extractor Agent output (structured intelligence objects):

```
{
  "entities": [
    {
      "type": "tool",
      "value": "macro-enabled spreadsheet"
    },
    {
      "type": "infrastructure",
      "value": "attacker-controlled domain"
    }
  ],
  "relations": [
    [
      "spreadsheet",
      "delivers",
      "loader"
    ]
  ],
  "behavioural_statements": [
    "adversary delivered a malicious macro document via a spoofed vendor email to gain initial access",
    "adversary established a scheduled task for persistence after loader execution"
  ]
}
```

Mapper Agent output: Each behavioural statement is independently mapped against the ATT&CK Enterprise catalogue via the hierarchy-aware knowledge layer (Section 3.5). For the first statement, the top-ranked candidates might plausibly be T1566 (Phishing) and its sub-technique T1566.001 (Spearphishing Attachment), each with a calibrated confidence score (Equation 3); for the second, T1053 (Scheduled Task/Job). Section 4 shows that even a non-LLM lexical baseline for this sub-task already ranks the correct top-level technique first in roughly half of comparable cases, and within the top three in nearly three quarters giving a sense of the difficulty an LLM-based mapper would need to improve upon.

Risk Assessor Agent output: Combining the mapped techniques' confidence and prevalence with hypothetical organisational context (e.g., email-based initial access is a historically likely vector for the organisation, $L \approx 0.7$; a successful loader execution on an unpatched endpoint would have high impact, $I \approx 0.8$; the affected asset class is business-critical, $C \approx 0.9$) yields, via Equation 1, a composite risk score used to prioritise the finding alongside a recommended mitigation (e.g., tightening attachment-execution policies and auditing scheduled task creation). The calibration constant α is organisation-specific: in practice, it would be set by an organisation against its own historical incident outcomes so that R values remain comparable across findings over time, rather than fixed a priori. This walkthrough is intended purely to clarify the data contract between agents; validating that each agent actually produces outputs of this quality is precisely the empirical work outlined in Section 7.2.

4 Preliminary Experiment: Mapper Agent Retrieval Baseline

To ground at least one part of this architecture in real measurement, we implemented and evaluated a non-LLM baseline for the Mapper Agent’s core retrieval sub-task described in Section 3.3: given a short free-text description of adversary behaviour, rank MITRE ATT&CK techniques by relevance.

4.1 Data

Technique catalogue. We downloaded the official MITRE ATT&CK Enterprise dataset (STIX 2.1 bundle, version 18) directly from MITRE’s public GitHub repository. After filtering revoked and deprecated objects, the catalogue contains 222 top-level techniques and 475 sub-techniques; for this baseline we restrict candidates to the 222 top-level techniques.

Evaluation set. We manually authored 49 short CTI-style behavioural descriptions, each hand-labelled with the single correct top-level ATT&CK technique, drawing on well-documented, publicly known adversary behaviours. Table 1 summarises the evaluation setup.

4.2 Method

We build a TF-IDF vector representation (unigrams and bigrams, English stopword removal) of each technique’s name and official MITRE description, and represent each evaluation sentence in the same vector space. For each sentence, we rank all 222 candidate techniques by cosine similarity and record the rank of the true label.

Table 2. Preliminary Mapper Agent retrieval results ($N = 49$ hand-labelled sentences, 222 candidate top-level techniques).

Method	Top-1 Acc.	Top-3 Acc.	MRR
Random ranking (analytic expectation)	0.004	0.014	0.027
TF-IDF cosine-similarity retrieval	0.531	0.714	0.655
LLM-based Mapper Agent (proposed)	Not yet evaluated	–	–
Full ThreatGPT pipeline	Not yet evaluated	–	–

4.3 Metrics

We report Top-1 and Top-3 accuracy, and Mean Reciprocal Rank:

$$\text{MRR} = \frac{1}{N} \sum_{i=1}^N \frac{1}{\text{rank}_i} \quad (4)$$

where rank_i is the rank position of the correct technique for the i -th evaluation sentence, and $N = 49$.

4.4 Results

Table 2 reports the real, measured results of this baseline, alongside the analytically computed expected performance of a random ranking over the same 222-technique candidate set.

The TF-IDF baseline correctly ranks the true technique first for just over half of the evaluation sentences (26/49) and within the top three for nearly threequarters (35/49), a very large improvement over random ranking (MRR 0.655 vs. 0.027). Inspection of the errors is informative: several of the baseline's failures are cases where the correct technique is a specific, low-frequency term, and cases where the sentence describes an effect of an action using vocabulary that does not lexically overlap with the official ATT&CK description text even though the semantic mapping is clear to a human analyst. Both failure modes are exactly what dense, semantically-aware LLM embeddings and generative re-ranking are designed to address.

4.5 What This Result Does and Does Not Show

This experiment demonstrates that our evaluation harness, real ATT&CK data pipeline, and metric implementation are correct and reproducible, and that even a simple lexical baseline achieves non-trivial mapping accuracy, giving a concrete floor for comparison. It does not demonstrate that the proposed LLM-based Mapper Agent, the Extractor Agent, the Risk Assessor Agent, the temporal weighting mechanism, or the adversarial defenses outperform this or any other baseline, because none of those components have yet been implemented and run.

5 Discussion

5.1 Practical Implications

If validated at full scale, an architecture along these lines could plausibly reduce SOC analyst triage time by structuring the extraction-mapping-assessment pipeline explicitly, integrating with existing SIEM/SOAR tooling via the structured intermediate objects each agent produces, and surfacing calibrated confidence scores so analysts can prioritise review effort.

5.2 Limitations

We are explicit about the current limitations of this work:

1. **No full implementation.** Only the Mapper Agent's core retrieval subtask has been prototyped, and only with a non-LLM baseline; the Extractor and Risk

- Assessor agents, the fine-tuning pipeline, the hierarchy-aware RAG index, and the adversarial defense layer are design proposals.
- 2. **Small, single-annotator evaluation set.** Our 49-sentence evaluation set was authored and labelled by the paper’s authors, not independently annotated CTI analysts, and is far smaller than established benchmarks.
 - 3. **Top-level-only label granularity.** Restricting to 222 top-level techniques rather than the full 697-technique catalogue makes the task easier than the full ATT&CK mapping problem.
 - 4. **Domain and language boundaries.** All proposed components are designed for English-language Enterprise ATT&CK content; behaviour on ICS/Mobile matrices or non-English CTI sources is untested.
 - 5. **Adversarial robustness is unvalidated.** The defense mechanisms are motivated by the published attack literature but have not been red-teamed against this specific architecture.
 - 6. **Cost and latency of the full pipeline are unknown** until an end-to-end implementation exists.

5.3 Ethical Considerations

An automated CTI system of this kind raises several considerations that deployers should weigh explicitly. First, the Extractor Agent processes third-party and potentially personal data present in OSINT and social-media text, raising data-protection questions. Second, LLM outputs can be miscalibrated or biased toward well-represented threat actors and English-language reporting, which could systematically under-serve analysis of threats reported primarily in other languages. Third, an accurate, automated TTP-mapping and risk-scoring capability is inherently dual-use. We believe transparency about capabilities and limitations, human-in-the-loop review for high-stakes outputs, and restricting deployment to defensive contexts are appropriate mitigations.

Table 3. Qualitative comparison with representative related systems.

System	Year	Core approach	Multi-agent?	Notes
TRAM [19]	2020/23	Supervised clas- No sifier + human review tool		MITRE Engenuity’s open-source ATT&CK mapping assistant
TechniqueRAG [4]	2025	Flat dense-retrieval No RAG		State-of-the-art flat RAG for CTIATT&CK mapping
Hierarchical RAG [4]	2026	Hierarchy-aware RAG	No	Motivates our knowledge-layer design
IntelEx [5]	2024	LLM-driven attack- No level extraction		Focused on extraction, not mapping or risk

CTINexus [6]	2024	In-context-learning No KG construction		Addresses data scarcity via optimised ICL
AgentSOC [1]	2026	Multi-layer agentic Yes SOC framework		Broader SOC scope; not CTI-mapping spe- cific
ThreatGPT	2026	Hierarchical Yes 3-agent ex- tract/map/assess		Explicit agent specialisation + temporal RAG + adversarial defense design

6 Related Work

Table 3 qualitatively situates ThreatGPT relative to representative recent systems across the categories most relevant to our architecture.

7 Conclusion and Future Work

7.1 Summary

We presented ThreatGPT, a hierarchical multi-agent architecture for LLMbased cyber threat intelligence analysis, decomposing the task into extraction, ATT&CK mapping, and organisational risk assessment, coordinated by a temporallyweighted, hierarchy-aware retrieval layer with adversarial-robustness safeguards designed in from the outset. We implemented and evaluated a real, reproducible non-LLM baseline for the Mapper Agent’s core retrieval sub-task against the official MITRE ATT&CK Enterprise catalogue, obtaining 53.1% top-1 accuracy and an MRR of 0.655 against a hand-labelled evaluation set a concrete floor for future comparison.

7.2 Future Work

We identify five concrete next steps:

1. Implement and evaluate the LLM-based Mapper Agent described in Section 3.3 against the same evaluation protocol as Section 4.
2. Build and evaluate the Extractor and Risk Assessor Agents, including finetuning the Extractor Agent on an annotated CTI corpus and validating Risk Assessor outputs against expert-assigned risk rankings.
3. Expand the evaluation set to a larger, multi-annotator, sub-technique-granularity benchmark.
4. Red-team the proposed adversarial defenses in Section 3.6 against realistic prompt-injection and RAG-poisoning attacks.
5. Extend the architecture to support non-English CTI sources and the ATT&CK ICS and Mobile matrices.

Reproducibility

The MITRE ATT&CK Enterprise dataset used in Section 4 is publicly available from MITRE’s official GitHub repository (<https://github.com/mitre/cti>). Our evaluation sentences, labels, and TF-IDF baseline code will be released at <https://github.com/REPLACE-WITH-ORG/threatgpt> upon publication.

References

1. AgentSOC: A Multi-Layer Agentic AI Framework for Security Operations Automation. IEEE (2026). arXiv:2604.20134.
2. LLM-Enabled Multi-Agent Systems: Empirical Evaluation and Insights into Emerging Design Patterns & Paradigms. arXiv:2601.03328 (2026).
3. Anthropic: Mapping AI-enabled cyber threats. Anthropic Research (2026). <https://www.anthropic.com/research/attack-navigator>.
4. Hierarchical Retrieval Augmented Generation for Adversarial Technique Annotation in Cyber Threat Intelligence Text. arXiv:2604.14166 (2026).
5. Xu, M., Wang, H., Liu, J., Lin, Y., Liu, C., Lim, H.W., Dong, J.S.: IntelEx: A LLMdriven attack-level threat intelligence extraction framework. arXiv:2412.10872 (2024).
6. Cheng, Y., Bajaber, O., Tsegai, S.A., Song, D., Gao, P.: CTINexus: leveraging optimized LLM in-context learning for constructing cybersecurity knowledge graphs under data scarcity. arXiv:2410.21060 (2024).
7. Fayyazi, R., Taghdimi, R., Yang, S.J.: Advancing TTP analysis: Harnessing the power of large language models with retrieval augmented generation. In: 2024 Annual Computer Security Applications Conference Workshops (ACSAC Workshops), pp. 255–261. IEEE (2024).
8. Huang, Y.T., Vaitheeshwari, R., Chen, M.C., Lin, Y.D., Hwang, R.H., et al.: MITREtrieval: Retrieving MITRE techniques from unstructured threat reports by fusion of deep learning and ontology. IEEE Trans. Netw. Serv. Manag. 21(4), 4871–4887 (2024).
9. Alam, M.T., et al.: CTIBench: A benchmark for evaluating LLMs in cyber threat intelligence. In: Proc. NeurIPS 2024, Datasets and Benchmarks Track, pp. 50805–50825 (2024).
10. Rahman, M.R., et al.: What are the attackers doing now? Automating cyberthreat intelligence extraction from text on pace with the changing threat landscape: A survey. ACM Comput. Surv. 55(12), 1–36 (2023).
11. Rahman, M.R., Williams, L.: From threat reports to continuous threat intelligence: A comparison of attack technique extraction methods from textual artifacts. (2022).
12. MITRE ATT&CK: State of the Art and Way Forward. arXiv:2308.14016 (2023).
13. Comparing AI Agents to Cybersecurity Professionals in Real-World Penetration Testing. arXiv:2512.09882 (2025).
14. Secure autonomous cyber defense with LLM agents: A systematic review of autonomy, tool-augmented reasoning, and governance constraints. Computers & Electrical Engineering (ScienceDirect) (2026).
15. Lewis, P., et al.: Retrieval-augmented generation for knowledge-intensive NLP tasks. In: Proc. NeurIPS 2020, pp. 9459–9474 (2020).

16. PoisonedRAG: Knowledge poisoning attacks to retrieval-augmented generation of large language models. USENIX Security (2025).
17. Prompt Injection Attacks in Large Language Models and AI Agent Systems: A Comprehensive Review of Vulnerabilities, Attack Vectors, and Defense Mechanisms. MDPI Information/Electronics (2026).
18. Wudali, P.N., et al.: Rule-ATT&CK Mapper (RAM): Mapping SIEM rules to TTPs using LLMs. arXiv:2502.02337 (2025).
19. Center for Threat-Informed Defense / MITRE Engenuity: TRAM: Threat Report ATT&CK Mapper. <https://github.com/center-for-threat-informed-defense/tram> (2020/2023).